

CompliVibe

Verified Feature Catalog

A complete, plain-language reference of every CompliVibe capability that is live, fully operational, and confirmed working by automated verification.

249

Verified, working features

19

capability domains covered

0

unverified or partially-working features
included

Scope & methodology. This catalog includes only capabilities classified as “Live and verified” in CompliVibe’s internal engineering audit — meaning each one is reachable in the product, does the real work it claims to do, and is backed by a passing automated test that exercises it end to end. Capabilities that are only partially working, carry a known defect, or are built but not yet automatically triggered have been deliberately left out of this document, even where they exist in the product today. This is a conservative, evidence-based list — nothing here is aspirational or in development.

Prepared July 19, 2026 • Confidential — for internal and authorised external use

CompliVibe at a Glance

How this catalog was scoped, and where the verified features are concentrated across the product.

249 “Live and verified” — included in this catalog	150 excluded
--	--------------

Out of 399 capabilities reviewed against CompliVibe's source code and automated test results, 249 are confirmed fully working and included below. The remaining 150 were reviewed and deliberately excluded — not because they don’t exist, but because they carry a known issue, are only partially working, or are not yet automatically triggered in production.

Verified features by domain



Part A — Quick-Find by Role

Use this index to jump straight to the capability areas most relevant to a given team or buyer. Every area listed here is covered in full, feature-by-feature detail in Part B.

Role / Function	Relevant Capability Domains (see Part B)
Compliance & GRC Teams	AI Governance, Frameworks & Regulatory Obligations, Vertical Compliance Satellites, Policy Management, Controls, Issues & Tasks, Reporting, Exports & Dashboards, AI-Assisted Communication & Platform Infrastructure, Governance Override Templates
Executives & the Board	Reporting, Exports & Dashboards, Risk Management, Organisation, Platform & Billing
Legal & Privacy Teams	Privacy & DPDP (India Data Protection), Vertical Compliance Satellites, Policy Management
Security & IT Teams	AI Governance, Vendor & Third-Party Risk Management, Data Observability, Integrations & Connectors, Authentication & Access Control, Vertical Compliance Satellites
Vendor Risk & Procurement	Vendor & Third-Party Risk Management, Vendor Security Questionnaires
Internal & External Auditors	Audit Management, AI-Assisted Communication & Platform Infrastructure, Reporting, Exports & Dashboards
AI Governance & ML Teams	AI Governance
Engineering / DevOps	Integrations & Connectors, Data Observability
Sales & Customer-Facing Security	Trust Center & Customer Commitments, Vendor Security Questionnaires
IT / Platform Administrators	Organisation, Platform & Billing, Authentication & Access Control, Governance Override Templates
HR / People Operations	Vertical Compliance Satellites
Risk Management	Risk Management, AI Governance

Part B — Full Verified Feature Catalog by Domain

The complete list, organised the same way CompliVibe's own engineering catalog is organised. Every entry below is confirmed live, functioning as described, and verified by automated tests.

Domain	Verified Features
AI Governance	81
Frameworks & Regulatory Obligations	23
Vertical Compliance Satellites	23
Policy Management	9
Privacy & DPDP (India Data Protection)	4
Controls	3
Organisation, Platform & Billing	18
Audit Management	4
Vendor & Third-Party Risk Management	14
Data Observability	7
Integrations & Connectors	7
Issues & Tasks	4
Authentication & Access Control	9
Reporting, Exports & Dashboards	15
Risk Management	2
AI-Assisted Communication & Platform Infrastructure	14
Vendor Security Questionnaires	5
Trust Center & Customer Commitments	6
Governance Override Templates	1
Total	249

AG

DOMAIN 01 OF 19

AI Governance

[AI Governance Teams](#) • [ML/Engineering Teams](#) • [Compliance](#)

The control tower for how an organisation governs its own AI systems — policy rules, human-approval workflows for automation, AI-specific risk scoring, and real integrations into live AI infrastructure such as Langfuse and MLflow.

Guardrail Policy Sets

Lets an organisation maintain named, versioned sets of AI-governance rules (e.g. how strictly change freezes are enforced). Every edit creates a new version rather than overwriting history, so there is always a permanent record of what the rules said on any date.

Technology: Deterministic rule engine (no AI); full version history with audit logging.

✓ LIVE & VERIFIED — Fully Operational

Guardrail Freeze Windows

A change-freeze calendar for AI governance activity — periods (e.g. year-end close, an active audit) during which review activity is blocked or flagged, scoped to specific AI systems or review types.

Technology: Deterministic scheduling and scope logic.

✓ LIVE & VERIFIED — Fully Operational

Guardrail Evaluation Engine

Given a proposed governance action, returns a clear allow/block decision, which freeze windows applied, and the exact policy version used — the single place in the guardrail system that produces an enforceable answer.

Technology: Deterministic rule evaluation over stored policy data.

✓ LIVE & VERIFIED — Fully Operational

Guardrail Policy Assignment Resolution

Automatically determines which guardrail policy applies to a given AI system, review type, or organisation-wide default, picking the most specific match and showing exactly why it was chosen.

Technology: Deterministic scope-resolution engine with full precedence trace and change history.

✓ LIVE & VERIFIED — Fully Operational

Policy Resolution Simulation

A "what-if" tool that shows which policy would apply to a hypothetical situation without touching any live configuration, and lets two simulated outcomes be compared side by side.

Technology: Deterministic simulation engine; results are saved and diffable.

✓ LIVE & VERIFIED — Fully Operational

Policy Diff Gating

Turns a raw list of policy differences into a severity verdict (info through critical) using rules the organisation defines, flagging when human review is required.

Technology: Configurable, deterministic severity classification.

✓ LIVE & VERIFIED — Fully Operational

Policy Diff Comparison Reports

Compares two severity classifications to show whether risk moved up or down and which specific rules changed — useful evidence that a configuration change reduced rather than increased risk.

Technology: Deterministic comparison engine.

✓ LIVE & VERIFIED — Fully Operational

Policy Diff Interpretation Presets

A reusable, versioned library of interpretation rules (e.g. "two or more high-severity changes = material regression") that can be pinned to a specific version so an evaluation stays reproducible over time.

Technology: Deterministic, versioned rule presets.

✓ LIVE & VERIFIED — Fully Operational

Policy Preset Assignment & Coverage Check

Automatically resolves which interpretation preset applies to a given AI system or review type, and runs a batch coverage check that flags any context with no matching preset before it becomes a blind spot.

Technology: Deterministic scope resolution with automated gap diagnostics.

✓ LIVE & VERIFIED — Fully Operational

Preset Assignment Diagnostic Reports

Saves the results of a preset coverage check as a durable, dated report an organisation can present as evidence that its policy assignments were complete on a given date, with side-by-side comparison between two reports.

Technology: Deterministic reporting and diffing.

✓ LIVE & VERIFIED — Fully Operational

Diagnostic Export Diffs

Compares two exported evidence packages and shows precisely what changed between them, down to the individual field — e.g. what's different between the report given to an auditor in March versus June.

Technology: Deterministic structural diff with a fixed reason-code catalogue.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Policies

Defines the rulebook for how much a proposed AI-governance action may be automated — which action types are allowed and which priority levels always require a human. Creating or editing a policy never causes anything to happen on its own; it is configuration only.

Technology: Deterministic policy engine with a safe-by-default fallback.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Approval Policies

Configures the human sign-off rules for automated proposals — how many approvers are required and how many rejections stop it.

Technology: Deterministic quorum configuration.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Candidate-Action Evaluation

A "what would happen if" check for a proposed automated action, returning allow / block / needs-approval with reasons. It independently re-derives the action's risk level rather than trusting what the caller claims, closing off a way to sneak a risky action past the gate.

Technology: Deterministic policy evaluation; nothing is written or executed by this check.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Execution Intents

Records a concrete, tamper-evident plan for a proposed automated action. A small, explicitly allow-listed set of low-risk actions (refreshing signals, flagging stale evidence, creating a follow-up task) can genuinely execute automatically — but only when the organisation has opted in and every safety gate passes; everything else is planning only.

Technology: Cryptographic hash-stamped intents with multi-factor auto-execution gate.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Executions & Reversal

The record of automated actions that actually ran, with a genuine one-time undo that restores exactly what changed. Includes an automatic circuit breaker that switches off auto-execution organisation-wide if reversals or execution volume spike unexpectedly.

Technology: Row-level locking with before/after snapshots; automatic safety circuit breaker.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Approvals & Quorum Voting

The human sign-off workflow for an automated action that needs approval — request approval, cast votes, see live quorum status — with guards against a person approving their own request.

Technology: Deterministic quorum computation with self-approval protection.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Capability Matrix & Runner Contract

Publishes an honest, itemised list of exactly what Autopilot can and cannot do, with each capability explicitly flagged as either planning-only or genuinely executing — no capability is ever overstated.

Technology: Transparent, self-documenting capability registry.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Runner Simulations

Builds and stores a dry-run of exactly what would be handed off for execution, so an organisation can inspect the full package before anything is built to send it.

Technology: Deterministic payload construction with idempotent hashing.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Runner Admissions

Issues one-time-display credentials for a future execution runner to identify itself, with the secret shown once and never recoverable from the database afterward.

Technology: Cryptographically random tokens, stored only as one-way hashes.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Runner Handshakes

Records a formal, tamper-evident greeting between the platform and a runner session, with built-in protection so a retried request cannot be double-counted.

Technology: Cryptographic hashing with replay protection.

✓ LIVE & VERIFIED — Fully Operational

Autopilot Operational Reports

Turns the automation activity log into genuine reporting: trend timelines, why actions were blocked, and an overall control-plane health verdict — real computed analytics, not placeholder numbers.

Technology: Live SQL aggregation with reproducibility checksums.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Assessment Lifecycle

A formal, structured risk assessment workflow for each registered AI system — likelihood, impact, and risk factors — moved through a controlled review process (draft, review, complete, archive), with every scoring calculation fully explained and preserved.

Technology: Deterministic weighted scoring with full audit trail; no AI in the scoring itself.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Assessment Snapshots

Takes a frozen, fingerprinted, point-in-time copy of a risk assessment, proving exactly what it said on a given date.

Technology: Cryptographic (SHA-256) fingerprinting of immutable snapshots.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Scoring Profiles

Lets an organisation define its own risk-scoring rules — how much weight likelihood and impact carry, and which score ranges count as low, medium, high or critical — rather than being locked into a vendor default.

Technology: Configurable, deterministic scoring with a preview mode.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Dimension Templates

Multi-dimensional risk scoring across named categories (bias, privacy, safety, etc.) with a weight per category, producing one combined score and risk band.

Technology: Deterministic weighted scoring.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Classification Taxonomies

Holds an organisation's own risk-classification vocabulary (for example EU AI Act risk tiers) — the reference list every classification decision must conform to.

Technology: Configurable, versioned taxonomy engine.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Classification Records

The formal record of which risk category applies to an AI system, asserted by a named human with a stated confidence level, and moved through a structured review workflow (submit, request changes, approve, reject).

Technology: Deterministic validation against the organisation's taxonomy; human judgement is always the source of truth.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Classification Snapshots

Tamper-evident, versioned history of every classification decision and every review step, so an auditor can reconstruct exactly what was decided and when.

Technology: Hash-chained, versioned snapshotting.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Recommendation Snapshots

Produces a frozen, dated "here's what needs attention" list for an organisation, a system, or an assessment, and shows exactly what changed since the last snapshot. Purely a reporting artefact for humans — it recommends but never acts.

Technology: Deterministic template assembly; no AI model is used.

✓ LIVE & VERIFIED — Fully Operational

Copilot Draft Snapshots

Saves a generated governance write-up (attention brief, review brief, executive risk summary) as a versioned, hashed record, so the exact wording shared with a board or auditor can be reproduced exactly, with line-level diffing between versions.

Technology: Deterministic template assembly — despite the "copilot" name, no AI model is involved.

✓ LIVE & VERIFIED — Fully Operational

Copilot Draft Previews

Generates a governance write-up on the fly (a brief for one system, an executive risk summary for the whole organisation) without saving it, ready to paste into a meeting pack.

Technology: Deterministic template filling; no AI model is involved.

✓ LIVE & VERIFIED — Fully Operational

Governance Signal Prioritisation

Ranks open AI-governance attention items so a compliance officer knows what to look at first, with the full reasoning shown — how much of the score came from severity, age, and how risky the related system is.

Technology: Deterministic, fully explainable scoring algorithm.

✓ LIVE & VERIFIED — Fully Operational

Governance Signal Lifecycle

The two actions available on an attention signal — mark it resolved, or dismiss it with a reason — each fully logged.

Technology: Deterministic state management with audit logging.

✓ LIVE & VERIFIED — Fully Operational

Governance Candidate Actions

Turns each open attention signal into a plain-English suggested next step, grouped and risk-tagged so destructive-sounding suggestions stand out. These are prompts for a person; nothing is carried out automatically.

Technology: Deterministic rule-based suggestion engine; no AI model is used.

✓ LIVE & VERIFIED — Fully Operational

AI System Governance Attention View

A one-screen answer to "how much trouble is this AI system in?" — open attention items, the highest priority one, and a breakdown by category, with a pointer to the most recent risk assessment.

Technology: Live, real-time aggregation.

✓ LIVE & VERIFIED — Fully Operational

AI Review Sequence Packs

Lets a compliance team define a reusable, ordered sequence of AI governance review steps (e.g. bias review, then security review, then executive sign-off) as a template.

Technology: Deterministic template engine with full audit logging.

✓ LIVE & VERIFIED — Fully Operational

AI Review Plan Constraints

Deterministic guardrails on when a review can be scheduled — for example, requiring a minimum gap after a prerequisite review — either blocking the schedule or flagging it for attention.

Technology: Deterministic rule evaluation.

✓ LIVE & VERIFIED — Fully Operational

AI Review Plan Run History

The full audit trail of every review-plan generation run: who ran it, over what horizon, and exactly what was planned, created or skipped and why.

Technology: Self-contained, immutable run records.

✓ LIVE & VERIFIED — Fully Operational

AI Review Reminder Policies

Configures the nudge timing for AI governance reviews — how many days before due date to remind, and when to mark overdue or escalate.

Technology: Configurable scheduling rules.

✓ LIVE & VERIFIED — Fully Operational

AI Review Summaries

Live dashboard counters for AI governance review scheduling, recurrence templates and sequence packs — always-current numbers with no drill-down needed.

Technology: Live SQL aggregation.

✓ LIVE & VERIFIED — Fully Operational

AI System Inventory & Lifecycle

The master register of an organisation's AI systems — create, edit, move through deployment stages, and retire without erasing history. Every change is written to a permanent event log and audit trail.

Technology: Full audit-logged CRUD with soft-delete history retention.

✓ LIVE & VERIFIED — Fully Operational

AI System Risk Classification (Guided)

Walks a user through a structured questionnaire about an AI system and derives a risk tier from the answers, with the option for an authorised person to manually override the result with a written justification.

Technology: Deterministic, rule-based scoring — not a model prediction.

✓ LIVE & VERIFIED — Fully Operational

EU AI Act Classification

Places an AI system into an EU AI Act risk category (prohibited / high-risk / limited / minimal) and lists the specific legal obligations that follow, using the platform's seeded Annex III mapping.

Technology: Rule-based lookup against a maintained regulatory mapping table.

✓ LIVE & VERIFIED — Fully Operational

NIST AI RMF Tracking

Tracks how far an AI system has implemented the NIST AI Risk Management Framework subcategory by subcategory, and computes an overall maturity level from the answers.

Technology: Deterministic maturity calculation.

✓ LIVE & VERIFIED — Fully Operational

AI Model Cards

Versioned documentation sheets describing a model's purpose, training data, limitations and performance. Publishing a new card automatically supersedes the previous one, with a full, tamper-detectable history.

Technology: Content hashing for tamper detection.

✓ LIVE & VERIFIED — Fully Operational

AI Bill of Materials (AIBOM)

Maintains the list of models, datasets, libraries and services each AI system is built from, with real version-to-version comparison showing exactly what was added, removed or changed.

Technology: Versioned records with genuine set-comparison diffing.

✓ LIVE & VERIFIED — Fully Operational

AI Guardrails Runtime Check

Lets an organisation define per-system operating rules (forbidden data categories, output constraints) and check a proposed AI action against them in real time, returning a permit-or-block decision with a full audit trail of every rule evaluated.

Technology: Deterministic policy engine, evaluated synchronously — no external calls, no AI model.

✓ LIVE & VERIFIED — Fully Operational

AI Deployment Approval Envelopes

A formal, multi-approver sign-off package for moving an AI system between deployment stages (e.g. into production), naming exactly who must approve before it proceeds — and once quorum is met, the system's status genuinely changes.

Technology: Deterministic quorum enforcement tied directly to production state.

✓ LIVE & VERIFIED — Fully Operational

AI System Monitoring Configuration

Configures what to watch on a live AI system (drift, accuracy, latency), stores the incoming readings, and shows a per-system dashboard with a consecutive-breach streak so a single blip doesn't trigger false alarms.

Technology: Configurable thresholds with API-key-authenticated ingestion.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Signal Review

Shows the automated risk signals raised against an AI system (such as a breached monitoring threshold) and lets a human triage each one, with staleness shown so old, unaddressed warnings stand out.

Technology: Live staleness computation.

✓ LIVE & VERIFIED — Fully Operational

AI Governance Recommendations

Produces a list of suggested governance actions for an AI system — for example, "no completed risk assessment" — based on what is and isn't present in its record. Fully rule-based; suggestions are advisory only.

Technology: Deterministic rule engine, not a language model.

✓ LIVE & VERIFIED — Fully Operational

AI System Event Log

A complete, read-only timeline of everything that has happened to an AI system — classifications, reviews, guardrail checks, status changes — for answering "show me the full history of this system."

Technology: Immutable, filterable event log.

✓ LIVE & VERIFIED — Fully Operational

AI System Use Cases

Records the specific business applications an AI system serves, including whether each is high-stakes, separating the underlying technology from how it is actually being used — which is how most AI regulation expects risk to be assessed.

Technology: Structured registry with strict parent/child integrity checks.

✓ LIVE & VERIFIED — Fully Operational

AI Governance Reviews

Runs a formal internal review of an AI system through a full lifecycle (create, schedule, start, complete or cancel), with a built-in separation-of-duties rule: the person who raised the review cannot approve it.

Technology: Enforced separation-of-duties state machine.

✓ LIVE & VERIFIED — Fully Operational

AI Risk Assessments (Weighted Question Bank)

A weighted, multi-dimension risk assessment spanning bias, privacy, security and more, plus the ability to compute real statistical fairness (bias) metrics directly from a company's own prediction data.

Technology: Real statistical bias-metric computation, not a black-box score.

✓ LIVE & VERIFIED — Fully Operational

EU AI Act Workflows

Three distinct EU AI Act obligations run as their own guided checklists — conformity assessment, Fundamental Rights Impact Assessment, and post-market monitoring plan — each gated so it cannot be marked complete while required items remain outstanding.

Technology: Enforced checklist completion gating.

✓ LIVE & VERIFIED — Fully Operational

Deployment Approval Decisions

The decision half of the deployment-approval process: named approvers vote, and once quorum is reached the AI system's deployment status genuinely moves to the approved state.

Technology: Quorum-gated production state changes — one of the few places in the platform where an approval directly changes live data.

✓ LIVE & VERIFIED — Fully Operational

Organisation-Level Guardrails

Creates and manages guardrail rules at the whole-organisation level (rather than per AI system), automatically applied everywhere alongside system-specific rules.

Technology: Deterministic rule engine, shared with the per-system guardrail check.

✓ LIVE & VERIFIED — Fully Operational

ISO/IEC 42001 Conformity Tracking

Tracks conformity with the ISO/IEC 42001 AI management-system standard clause by clause, with status, notes and linked evidence per clause, and a live summary of overall conformity.

Technology: Auto-initialised per organisation from the seeded ISO clause set.

✓ LIVE & VERIFIED — Fully Operational

LLM Observability

Genuine, substantive monitoring of live LLM applications — pulls real trace data from a connected Langfuse instance, scores outputs for hallucination and retrieval quality, and computes actual dollar cost per token from a real pricing table.

Technology: Real integration with Langfuse; hallucination/RAG-quality scoring via the DeepEval library. Advisory only — never blocks live traffic.

✓ LIVE & VERIFIED — Fully Operational

MLOps Integrations

A registry of connections to MLOps platforms (MLflow, Databricks, SageMaker, Vertex AI) that automatically pulls in registered models and reconciles them into the AI system inventory and Bill of Materials — one of the few AI-governance engines that runs on a fully automatic daily schedule.

Technology: Real MLflow client integration; credentials encrypted at rest; automated daily sync.

✓ LIVE & VERIFIED — Fully Operational

MLOps Ingest Webhook

An inbound channel that lets a customer's MLflow deployment push model-registration and drift events directly into CompliVibe in real time, authenticated by a per-organisation token.

Technology: Token-authenticated, event-driven ingestion.

✓ LIVE & VERIFIED — Fully Operational

MLflow Connection Management

The administrative side of the MLflow integration: create and rotate ingest tokens, browse incoming models and drift events, manually link a model to an AI system, and view a coverage report of how much of the estate is actually covered by MLOps telemetry.

Technology: Secure, rotatable, one-time-display tokens.

✓ LIVE & VERIFIED — Fully Operational

AI Monitoring Reading Ingestion

Two ways a metric reading reaches the monitoring system — a person submitting one manually, or an unattended monitoring agent posting one automatically — each checked against its threshold and capable of raising a real alert.

Technology: API-key-authenticated automated ingestion path.

✓ LIVE & VERIFIED — Fully Operational

NIST RMF Organisation Summary

A single organisation-wide view of NIST AI RMF maturity, aggregated across every AI system with a maturity record — answering "how mature are we overall," not just system by system.

Technology: Live aggregation.

✓ LIVE & VERIFIED — Fully Operational

Agentic Policy Derivation (Patent Technology)

Turns written regulatory obligations into machine-enforceable policy that can genuinely block an AI agent's action in real time, with a cryptographically verifiable, tamper-evident audit trail of every allow/deny decision — unlike most guardrail features in the platform, this one is a real, live enforcement point.

Technology: Real Open Policy Agent (OPA) compilation and evaluation; genuine Ed25519 cryptographic signatures, hash-chained receipts; fails closed if unreachable.

✓ LIVE & VERIFIED — Fully Operational

Recommendation Disposition (Apply as Task)

Lets a user act on a generated recommendation — dismiss it, or apply it, which creates a real, assigned follow-up task so the work is genuinely tracked rather than the system claiming to have done anything itself.

Technology: Human-in-the-loop task creation; nothing is auto-executed.

✓ LIVE & VERIFIED — Fully Operational

Organisation-Wide Risk Signal List

One combined view of every AI risk signal across all systems in the organisation, filterable by system, type, status and severity.

Technology: Live, filterable aggregation.

✓ LIVE & VERIFIED — Fully Operational

Shadow AI Detection & Registration

Manages "shadow AI" — AI tools in use across the business that were never formally registered. A reported tool is reviewed by a governance owner and either dismissed with a reason or promoted into a fully registered, governed AI system.

Technology: Human-reported detection with a full review-and-promotion workflow.

✓ LIVE & VERIFIED — Fully Operational

Third-Party AI Assessments

Assesses the AI capabilities embedded in a vendor's product — the specific questionnaire a supplier's AI functionality goes through — culminating in a finalised risk level.

Technology: Structured questionnaire with deterministic risk finalisation.

✓ LIVE & VERIFIED — Fully Operational

AI Governance Diagnostic Snapshots

A point-in-time health report on the organisation's entire AI governance posture — walking every AI system and scoring it on assessment currency, regulatory category, drift alerts, monitoring coverage and open recommendations, exportable as PDF or Word for a board or auditor.

Technology: Weighted, deterministic scoring across six live data sources.

✓ LIVE & VERIFIED — Fully Operational

AI Governance Event Log (Organisation-Wide)

The organisation-wide version of the AI governance timeline — every event across every AI system, filterable by type and date, with a count-by-type summary answering "what has our AI governance programme actually been doing."

Technology: Immutable, filterable event log.

✓ LIVE & VERIFIED — Fully Operational

AI System Registry (Core Inventory)

Maintains the organisation's inventory of AI systems that every other AI-governance feature hangs off — create, list, update, archive, with ownership validated against real active organisation members.

Technology: Full audit-logged CRUD.

✓ LIVE & VERIFIED — Fully Operational

AI System Cross-Domain Links

Connects an AI system to the controls that govern it, the evidence that proves those controls, and the risks it carries — turning the AI register from a plain list into something genuinely auditable, with a six-way coverage summary.

Technology: Link-history preservation (nothing is silently deleted).

✓ LIVE & VERIFIED — Fully Operational

AI System Governance Reviews (Core)

Runs a formal internal review of an AI system through create, schedule, start, complete or cancel, with every response explicitly labelled as an internal governance checkpoint — not legal advice or regulatory approval.

Technology: Enforced state-machine transitions with full audit logging.

✓ LIVE & VERIFIED — Fully Operational

AI System Governance Summary

A single view of one AI system's governance posture — review counts by status, type and outcome, and how many formal attestations have been signed.

Technology: Live, real-time aggregation.

✓ LIVE & VERIFIED — Fully Operational

AI Vendor Assessments

A structured, roughly 25-field questionnaire assessing a vendor's AI product — data handling, bias testing, human oversight, explainability, and regulatory obligations — producing a transparent risk score and band, with a portfolio view rolling all vendors up together.

Technology: Transparent, published weighted rubric — not a black-box or AI-generated score.

✓ LIVE & VERIFIED — Fully Operational

Synthetic Dataset Governance

A register of synthetic datasets, recording which real dataset each derives from and which privacy technique was applied, calculating a real, citation-backed re-identification risk estimate and flagging governance gaps (such as a dataset marked "validated" with no privacy technique applied at all).

Technology: Published academic risk formulas (k -anonymity and differential-privacy bounds), with tighter thresholds automatically applied for higher-risk AI systems.

✓ LIVE & VERIFIED — Fully Operational

Training Dataset Rights Register

Records the datasets used to train an organisation's AI systems — licence, source, provenance, rights-expiry date — and surfaces a rights-gaps report answering "are we legally entitled to have trained on this?"

Technology: Deterministic gap analysis against real stored dates and documentation status.

✓ LIVE & VERIFIED — Fully Operational

Training Completion Analytics

Tracks assigned versus completed mandatory training by business unit, flagging units genuinely trending toward non-compliance, with the exact rule used returned alongside the flag so nobody has to guess what it means.

Technology: Transparent, rule-documented analytics.

✓ LIVE & VERIFIED — Fully Operational

FRO

DOMAIN 02 OF 19

Frameworks & Regulatory Obligations

[Compliance & GRC Teams](#) • [Legal](#) • [Auditors](#)

The compliance content backbone — the library of regulatory frameworks, the engine that works out which obligations actually apply to a given organisation, and the reviewer-capacity and batch-assignment tooling that keeps large compliance content operations moving.

Framework Catalog & Versions

The master library of compliance frameworks (SOC 2, ISO 27001, GDPR, DORA and more), their published versions and section structure, with the ability to switch a framework on or off for a given organisation.

Technology: Structured, versioned content catalogue.

✓ LIVE & VERIFIED — Fully Operational

Framework Applicability Engine

Works out which obligations in a framework genuinely apply to an organisation, based on questions answered about the business, producing a suggested applicable / not-applicable / needs-review verdict with a written rationale for each. A human always confirms the final state.

Technology: Deterministic rule engine with a fixed operator set; genuinely detects when an answer has gone stale and automatically flags it for re-review.

✓ LIVE & VERIFIED — Fully Operational

Framework Coverage Reports

Reports how completely a framework's content has been authored — obligation text, evidence requirements, control suggestions — and highlights the gaps, with a clear stated caveat that this measures content completeness, not organisational compliance.

Technology: Live aggregation with persisted historical snapshots.

✓ LIVE & VERIFIED — Fully Operational

Framework Semantic Mapping

Finds obligations in one framework that mean roughly the same thing as obligations in another (e.g. matching ISO 27001 work against SOC 2), using genuine meaning-based matching rather than keyword search, with an honest fallback and status indicator when the advanced matching isn't available.

Technology: Real sentence-transformer embeddings with vector similarity search; degrades transparently to keyword matching when unavailable.

✓ LIVE & VERIFIED — Fully Operational

Framework Obligations Listing

Lists the obligations belonging to a framework with filters for status, jurisdiction and free-text search.

Technology: Filtered, paged search.

✓ LIVE & VERIFIED — Fully Operational

Framework Content Review Runs

A formal record that someone reviewed a framework's authored content before it is promoted — who reviewed it, what type of review, and the outcome — with each sign-off cryptographically checksummed against tampering.

Technology: Checksummed, signed review records.

✓ LIVE & VERIFIED — Fully Operational

Framework Content Promotion

Controls when a framework's content is allowed to move up a maturity ladder from bare metadata to fully verified. Promotion to the top tier is genuinely gated on at least two independent sign-offs and zero missing content, re-verified at the moment of execution rather than trusted from an earlier check.

Technology: Multi-stage, re-verified promotion gate.

✓ LIVE & VERIFIED — Fully Operational

Framework Review Assignments

Assigns a named person to review a framework content pack and tracks the assignment through accept, complete and cancel, with the assignee automatically notified by email.

Technology: Validated against real active organisation membership before assignment.

✓ LIVE & VERIFIED — Fully Operational

Framework Review Queue

The reviewer's personal workload — what's assigned to me, what's outstanding organisation-wide, and a summary count view.

Technology: Live, filtered queries.

✓ LIVE & VERIFIED — Fully Operational

Reviewer Capacity Policies

Lets an administrator set how much review work a given role should carry — maximum active assignments, maximum overdue, and a target coverage level.

Technology: Configurable policy inputs consumed by the workload and suggestion engines.

✓ LIVE & VERIFIED — Fully Operational

Reviewer Workload Snapshots

Gives every reviewer a 0–100 capacity score so managers can see at a glance who is swamped and who has room, computed with a fully transparent, published formula.

Technology: Deterministic, explainable scoring formula.

✓ LIVE & VERIFIED — Fully Operational

Reviewer Assignment Suggestion Engine

Recommends who should review a given framework pack, ranked, with the full reasoning shown — the same inputs always produce the same recommendation, so a manager can see and argue with exactly why it was suggested.

Technology: Deterministic, fully transparent scoring — not a black-box AI recommendation.

✓ LIVE & VERIFIED — Fully Operational

Reviewer Capacity Simulations

A what-if planner projecting how a proposed reviewer workload would land, including multi-wave scheduling, entirely read-only — nothing is written to the database.

Technology: Deterministic simulation engine with explicit stated assumptions.

✓ LIVE & VERIFIED — Fully Operational

Batch Assignment Runs

Assigns many framework reviews to many reviewers in a single confirmed operation — protected by a two-phase preview-then-confirm flow that automatically detects if the underlying data changed between preview and execution.

Technology: Plan-hash verification prevents the classic bulk-action "stale plan" mistake.

✓ LIVE & VERIFIED — Fully Operational

Batch Cancellation Dual Approval

Requires a second person to sign off before a bulk assignment run can be cancelled, when the organisation has configured that requirement — a genuine, configurable control rather than decoration.

Technology: Configurable dual-approval gate.

✓ LIVE & VERIFIED — Fully Operational

Framework Content Packs (11 Regulatory Frameworks)

Ships genuinely pre-written content for eleven frameworks — GDPR, SOC 2, ISO 27001, ISO 42001, PCI DSS, DORA, EU AI Act, NIST AI RMF, Colorado AI Act and two RBI (India) packs — covering obligation text, evidence requirements, control suggestions and applicability questions, with built-in validation before anything is applied.

Technology: Real, versioned content packs with automated consistency checking.

✓ LIVE & VERIFIED — Fully Operational

Obligation Detail & State Management

The single-obligation view: full text, the controls that cover it, its equivalents in other frameworks, semantically similar obligations, and the organisation's applicability decision. Overriding the applicability engine's suggestion requires a written justification.

Technology: Governed override with mandatory justification.

✓ LIVE & VERIFIED — Fully Operational

Obligation Applicability Rules

Manages the individual rules the applicability engine evaluates — the "if this, then that obligation applies" logic — with archiving that preserves history rather than deleting it.

Technology: Deterministic, validated rule authoring.

✓ LIVE & VERIFIED — Fully Operational

Obligation Control Suggestions

Shows suggested controls that would satisfy a given obligation, with a one-click action to turn a suggestion into a real, live control in the register — safely repeatable without creating duplicates.

Technology: Idempotent control creation.

✓ LIVE & VERIFIED — Fully Operational

Obligation Content Version History

Keeps a full, append-only revision history of an obligation's authored text, so exactly how the wording changed over time is always visible.

Technology: Append-only versioning — nothing is ever overwritten.

✓ LIVE & VERIFIED — Fully Operational

Obligation Evidence Requirements

Records what evidence type an obligation expects and how often it should be refreshed, defining the target for evidence-collection work.

Technology: Structured specification store.

✓ LIVE & VERIFIED — Fully Operational

OSCAL Export (NIST Machine-Readable Format)

Exports control and assessment data in OSCAL — the NIST machine-readable format US federal programmes and GRC tools consume — producing system security plans, assessment plans and assessment results.

Technology: Genuine OSCAL 1.1.2-compliant JSON generation with real enumeration translation, downloadable and independently validatable.

✓ LIVE & VERIFIED — Fully Operational

Regulatory Change Alerts

Genuinely watches live public regulatory sources and raises an alert when something new appears that touches a framework the organisation has active — fully automated, running on its own every day.

Technology: Real, automated daily polling of EUR-Lex and NIST CSRC feeds; deduplicated and error-tracked.

✓ LIVE & VERIFIED — Fully Operational

VCS

DOMAIN 03 OF 19

Vertical Compliance Satellites

Operations & Business Continuity • Legal • IT/OT Security • ESG/Sustainability • HR

Fifteen specialised modules covering business continuity, resilience testing, DORA, industrial control systems, carbon accounting, whistleblower intake, legal matters, IP assets, employee offboarding, segregation of duties, machine identities, privileged access, breach notification, and organisational structure.

Business Process Register

A register of an organisation's critical business processes — owner, criticality tier, recovery time and recovery point objectives — the foundation record for business continuity planning.

Technology: Structured registry with ownership and dependency validation.

✓ LIVE & VERIFIED — Fully Operational

Continuity Review Overdue Detection

Flags exactly which business processes are due for a continuity review — never assessed, assessment older than its own review cadence, or the named owner has left — automatically excluding processes that have themselves been retired.

Technology: Live staleness computation across the process register.

✓ LIVE & VERIFIED — Fully Operational

Resilience Test Register

Maintains a register of operational-resilience tests (DORA-style scenario or penetration tests) with automatic cross-checking against the organisation's DORA third-party provider register, so gaps in coverage are visible.

Technology: Automated cross-referencing against the live ICT provider register.

✓ LIVE & VERIFIED — Fully Operational

Resilience Test Completion & Auto-Issue Creation

Recording that a resilience test has finished automatically turns critical or high-severity findings into tracked Issues in the compliance register, so a failed test never just sits in a report — and re-completing the same test never creates duplicates.

Technology: Automated, idempotent issue creation.

✓ LIVE & VERIFIED — Fully Operational

DORA Testing Cadence Compliance

Tells you exactly which resilience tests are overdue under DORA's real testing frequencies, citing the specific article (Article 24 or 26) being applied, and treats an organisation with no completed test as overdue rather than defaulting to compliant.

Technology: Regulation-cited, deterministic cadence calculation.

✓ LIVE & VERIFIED — Fully Operational

DORA ICT Third-Party Register

Maintains the register of ICT third-party providers required under DORA, and automatically raises a Risk, an alert and an Issue the moment a genuine gap is detected — such as a critical provider with no documented exit strategy.

Technology: Event-driven, automated gap-to-risk escalation.

✓ LIVE & VERIFIED — Fully Operational

OT/ICS Collector Agent Registration

Registers software collectors that sit inside an operational-technology or industrial-control network and report findings back to CompliVibe, with the credential shown exactly once and never recoverable afterward.

Technology: Cryptographically random tokens, one-way hashed at rest.

✓ LIVE & VERIFIED — Fully Operational

OT/ICS Asset Inventory

An inventory of operational-technology and industrial-control assets, with the option to link an OT asset to its corresponding IT data asset — recording exactly where the two worlds converge.

Technology: Structured registry with cross-domain linking.

✓ LIVE & VERIFIED — Fully Operational

OT/ICS Findings Review

The analyst view of security findings reported from OT/ICS collectors — list, filter, resolve — with a genuinely useful segment-level view that surfaces where high/critical findings are clustering, a pattern no single finding would reveal.

Technology: Automated clustering aggregation.

✓ LIVE & VERIFIED — Fully Operational

Carbon Data Ingest Key Issuance

Issues a dedicated, rotatable API key so an external emissions system can push readings directly into CompliVibe, shown once and stored only as a one-way hash.

Technology: One-way hashed key storage.

✓ LIVE & VERIFIED — Fully Operational

Carbon Emissions Reading Ingest

Accepts emissions readings pushed from an external system, tagged by scope, Scope-3 category and reporting period, with genuine correction handling so a restated figure supersedes the original rather than double-counting.

Technology: API-key-authenticated ingestion with real correction (non-duplicating) semantics.

✓ LIVE & VERIFIED — Fully Operational

Whistleblower Case Management

The investigator side of the anonymous hotline: list, open and reply to reports through the tracking-code channel, moving cases through a forward-only lifecycle. Applies the EU Whistleblower Directive's real service-level timers (7-day acknowledgement, 90-day feedback) as advisory flags for the investigator.

Technology: Regulation-cited SLA tracking; forward-only status transitions prevent cases being quietly walked backward.

✓ LIVE & VERIFIED — Fully Operational

Legal Matter Lifecycle Management

Tracks legal matters (disputes, regulatory actions, investigations) through their lifecycle and links each to related risks and compliance issues, with two built-in guardrails: status can never be changed by an ordinary edit, and closing a matter with open linked issues requires explicit confirmation.

Technology: Deliberate lifecycle guardrails preventing accidental status changes.

✓ LIVE & VERIFIED — Fully Operational

IP & Licence Asset Registry

A register of intellectual-property and licensing assets — patents, trademarks, model and dataset licences — with optional linkage to the AI system that uses them, and soft deletion so nothing simply disappears.

Technology: Structured registry with cross-domain validation.

✓ LIVE & VERIFIED — Fully Operational

IP & Licence Expiry Intelligence

Surfaces which IP and licence records are approaching expiry within an organisation-configurable window, ranked so that an expiring model licence attached to a live, at-risk AI system is shown first.

Technology: Risk-weighted ranking, not simple date sorting.

✓ LIVE & VERIFIED — Fully Operational

Offboarding Execution

When an employee leaves, genuinely revokes their platform access — deactivates their account, kills active login sessions, revokes outstanding activation tokens, and bulk-reassigns everything they owned (risks, controls, tasks, policies, vendors, audit engagements) to a successor, all in one transaction with a permanent record of exactly what was reassigned.

Technology: Real, verified session revocation and ownership reassignment — confirmed by dedicated security-focused tests. Internal to CompliVibe only; does not reach external identity providers.

✓ LIVE & VERIFIED — Fully Operational

Segregation-of-Duties Rule Registry

Defines pairs of permissions that no single person should hold at once, validating both permissions against the real permission catalogue and correctly rejecting a duplicate rule regardless of the order the pair is entered in.

Technology: Canonical-pair deduplication against a validated permission catalogue.

✓ LIVE & VERIFIED — Fully Operational

Segregation-of-Duties Detection

Actually evaluates an organisation's segregation-of-duties rules against what people can genuinely do — resolving each user's real, live effective permissions and reporting any rule where both permissions land on the same person. Findings can be acknowledged or formally waived with a reason.

Technology: Live evaluation against real role-to-permission data, not a static or pre-seeded list.

✓ LIVE & VERIFIED — Fully Operational

Non-Human Identity Registry

An inventory of service accounts, API keys, bots and machine credentials, recording ownership, rotation due date and risk level — where marking an identity inactive or orphaned genuinely cascades into its risk level automatically.

Technology: Real cascading state changes, validated against active organisation membership.

✓ LIVE & VERIFIED — Fully Operational

Breach Notification Lifecycle

Manages a personal-data or ICT breach from detection to closure against real regulatory clocks — 72 hours for GDPR, 4 hours for a DORA early warning, 24 hours for NIS2, 60 days for HIPAA — and genuinely refuses to let a breach be closed until required notifications have actually been recorded. A daily automated sweep queues warning emails as deadlines approach.

Technology: Regulation-cited deadline computation with a fully automated, scheduled daily sweep — one of the platform's most substantive compliance-automation features.

✓ LIVE & VERIFIED — Fully Operational

Article 33 Breach Notification Drafting

Produces a first draft of a regulatory breach notification, correctly titled and cited for the applicable regime (GDPR, HIPAA, DORA or NIS2). By default a transparent template; if an organisation has explicitly opted in, it can call an AI model for the narrative — and always tells the reviewer honestly which one was used.

Technology: Deterministic template by default; optional, clearly-flagged AI assistance (Azure OpenAI) with automatic fallback to the template on any failure. Suggestion-only — a human always reviews before anything is sent to a regulator.

✓ LIVE & VERIFIED — Fully Operational

Business Unit Hierarchy

Models the organisation's internal structure as a tree of business units, with real protective rules — no reparenting that would create a loop, no deactivating a unit that still has active children, no deleting a unit that has children at all, and every refusal names the specific blocking children.

Technology: Automated cycle detection before any structural change is accepted.

✓ LIVE & VERIFIED — Fully Operational

Business Unit Entity Tagging

Assigns a record — risk, control, policy, vendor or AI system — to a business unit, so results can be rolled up and reported by division, with both the business unit and the target record validated to belong to the same organisation.

Technology: Tenant-validated tagging across five record types.

✓ LIVE & VERIFIED — Fully Operational

PM

DOMAIN 04 OF 19

Policy Management

[Compliance & GRC Teams](#) • [Legal](#) • [Employees \(attestation\)](#)

The full lifecycle of written organisational policy — drafting, version control, formal multi-person approval, control mapping, and the employee-facing campaigns that collect a documented, signed record of who has read and agreed to each policy.

Policy Register & Lifecycle

Keeps an organisation's written policies in one place — create, edit, retire without deleting the record — with an at-a-glance summary of how many policies sit in each state and which open compliance issues are attached to a given policy.

Technology: Full audit-logged CRUD with soft archival.

✓ LIVE & VERIFIED — Fully Operational

Policy Version Control

Every policy keeps a numbered, permanent history of its text. Older versions are never overwritten, two versions can be compared to show exactly what changed, and a version can be formally pushed into the approval stage.

Technology: Immutable version history with genuine text-diff comparison.

✓ LIVE & VERIFIED — Fully Operational

Policy Approval Workflow

Formal, auditable sign-off on a policy version — a named approver approves, rejects, or the request is cancelled, with a built-in rule blocking anyone from approving their own request.

Technology: Enforced self-approval prevention; full audit trail on every decision.

✓ LIVE & VERIFIED — Fully Operational

Policy-to-Control Linking

Connects a policy to the specific controls that implement it, so an auditor can be shown exactly which controls back a given policy, with a rolled-up per-policy count.

Technology: Link-history preservation.

✓ LIVE & VERIFIED — Fully Operational

Policy Issue Linking

Records that a compliance issue relates to a policy, with linking, unlinking, and a computed violation rate showing how many issues are attached to each policy.

Technology: Live rate computation.

✓ LIVE & VERIFIED — Fully Operational

Policy-to-Risk Mapping

Records which risks a policy is intended to mitigate, with bidirectional coverage reporting — which risks a policy addresses, and which policies address a given risk.

Technology: Full CRUD with live coverage aggregation in both directions.

✓ LIVE & VERIFIED — Fully Operational

Policy Attestation Campaigns

Runs the employee-facing side of policy sign-off — an administrator opens a campaign against a policy, and staff either attest that they've read it or decline with a reason, with each signature recorded together with the acting user's identity and timestamp.

Technology: Timestamped, IP-recorded attestation records for a genuine, defensible sign-off trail.

✓ LIVE & VERIFIED — Fully Operational

Employee Attestation Administration

The administrator's view of attestation campaigns — a completion dashboard, per-person breakdown, bulk and individual reminders, exempting a named person, and amending or cancelling a campaign entirely.

Technology: Live completion tracking with genuine email reminder dispatch.

✓ LIVE & VERIFIED — Fully Operational

Attestation Access Tokens

Issues single-purpose, secure links that let an outside party complete an attestation without holding an account, with the ability to revoke a link or check whether it is still valid at any time.

Technology: Signed, opaque tokens; only a hash is stored, never the token itself.

✓ LIVE & VERIFIED — Fully Operational

PDI

DOMAIN 05 OF 19

Privacy & DPDP (India Data Protection)

[Legal & Privacy Teams](#) • [DPO](#)

Genuine, working implementations of specific India DPDP Act rights — data-principal nomination, the record of processing activities (RoPA), notification preferences, and cookie-consent banner management.

Cookie Registry & Consent Banner

Maintains a register of the cookies a website sets, with a single consent-banner configuration an organisation controls and a public page that renders it — external scanner findings can be pushed in and the register updates to match automatically.

Technology: Automated scan-report reconciliation.

✓ LIVE & VERIFIED — Fully Operational

Data-Principal Nomination (DPDP)

Implements the Indian DPDP Act right for a person to nominate someone to exercise their data rights on their behalf, for example in the event of death or incapacity, with the subject's identity never stored in the clear.

Technology: Salted, one-way hashed identifiers — genuine implementation of a specific DPDP right, not just a labelled field.

✓ LIVE & VERIFIED — Fully Operational

Notification Preferences

Lets each person choose, per organisation, which compliance notifications they receive, on which channel, and above what severity.

Technology: Personal, user-controlled configuration.

✓ LIVE & VERIFIED — Fully Operational

Record of Processing Activities (RoPA)

The Article 30 master inventory of what personal data an organisation processes, why, on what legal basis, and where it goes — linked to the specific obligations each activity satisfies and exportable as a formal Article 30 report generated from live, current data.

Technology: Genuine cross-field validation (e.g. special-category data automatically forces an impact-assessment requirement); the strongest-verified module in the privacy area.

✓ LIVE & VERIFIED — Fully Operational



DOMAIN 06 OF 19

Controls

[Compliance & GRC Teams](#) • [Internal Audit](#)

The master register of every control an organisation operates, real cross-framework coverage analysis, and organisation-wide alert triage for monitoring breaches.

Controls Register

The master list of every control an organisation operates — what it is, who owns it, whether it's implemented, and which regulatory obligations it satisfies — with real coverage reporting answering which obligations have no control, how often controls fail, and how much of each framework is genuinely covered.

Technology: Live SQL-driven gap, failure-rate and framework-coverage analysis.

✓ LIVE & VERIFIED — Fully Operational

Control Monitoring Alert Triage

The worklist for alerts raised by control monitoring — acknowledge, assign, resolve, dismiss, or promote a serious alert straight into a fully tracked compliance Issue for remediation.

Technology: Real, linked issue creation from an alert.

✓ LIVE & VERIFIED — Fully Operational

Common-Control Cross-Framework Mapping

Finds the controls that genuinely satisfy more than one framework at once, so an organisation can test a control once and satisfy several standards, reporting coverage percentages and flagging where the same control has been mapped with inconsistent strength across frameworks.

Technology: Live cross-framework union query with real conflict detection.

✓ LIVE & VERIFIED — Fully Operational



DOMAIN 07 OF 19

Organisation, Platform & Billing

[IT / Platform Admin](#) • [Finance](#) • [Security](#)

Core organisation administration — governance settings, tamper-evident evidence manifests, self-serve onboarding, real Razorpay-backed billing, SES-based email configuration, SIEM export, and the operator-facing scheduler and rate-limit console.

Organisation Profile Management

The basic organisation record — read and edit organisation details, with every change written to a permanent, before/after audit record.

Technology: Full audit-logged updates.

✓ LIVE & VERIFIED — Fully Operational

Governance Settings Control Panel

A single per-organisation panel for six governance-critical switches — batch cancellation approval, Autopilot auto-execution, the confidence threshold it must clear, the reversal window, and graph-reasoning enablement. Every change is versioned rather than overwritten, so the exact history of when automation authority was granted is always available.

Technology: Fully versioned settings history.

✓ LIVE & VERIFIED — Fully Operational

Governance Settings Rollout to Open Work

Applies a changed governance default onto batch review runs already in flight, so a policy change genuinely reaches work in progress rather than only new work — with a dry-run mode showing exactly what would change before anything is written.

Technology: Dry-run-first change application.

✓ LIVE & VERIFIED — Fully Operational

Governance Settings History & Timeline

The full audit trail for governance switches — every past version, merged with related audit-log entries into one chronological stream, plus a side-by-side diff between any two versions.

Technology: Merged, chronological audit reconstruction.

✓ LIVE & VERIFIED — Fully Operational

Governance Evidence Bundle

Packages the current governance settings and their full change history into a single downloadable structure, ready to attach to an audit response.

Technology: Point-in-time JSON evidence assembly.

✓ LIVE & VERIFIED — Fully Operational

Governance Manifest Verification Log

The permanent log of every time a governance evidence manifest was verified — who checked it, when, and whether it passed — answering "has anyone actually checked this evidence, and did it hold up?"

Technology: Immutable, filterable verification event log.

✓ LIVE & VERIFIED — Fully Operational

Governance Manifest Chain of Custody

Assembles the complete, ordered life story of a single governance evidence manifest — generation, every verification, revocation and the signing key's own history — into one chronological view.

Technology: Merged, multi-source chronological reconstruction.

✓ LIVE & VERIFIED — Fully Operational

Self-Serve Organisation Onboarding

The public sign-up flow — a visitor creates a new organisation and admin account, checks workspace-name availability, and sees available plans, landing with a working session immediately rather than at a login screen.

Technology: Automated organisation, role and default-policy seeding on sign-up.

✓ LIVE & VERIFIED — Fully Operational

Onboarding Framework Selection & Checklist

The core of the setup wizard: select the frameworks an organisation needs, which automatically activates them and seeds a starter set of controls, with a checklist computed live from real data (do you have controls, evidence, risks, invited teammates) rather than static wizard state.

Technology: Live-data-driven checklist — cannot report a step as done when it genuinely isn't.

✓ LIVE & VERIFIED — Fully Operational

First-Day Compliance Baseline

A guided first-day assessment that generates intake questions tailored to the frameworks selected and can pull real evidence directly from a connected GitHub organisation (repositories, branch protection, Dependabot and secret-scanning alerts), producing an early gap report before any manual work has begun.

Technology: AI-generated intake questions (with a deterministic fallback if the model is unavailable) plus genuine, real-time GitHub REST API evidence collection. Generated content is intake prompts for a human, not automated findings.

✓ LIVE & VERIFIED — Fully Operational

Subscription Billing (Razorpay)

A real, live payment integration — subscribe to a plan, view current subscription status, browse plans, view invoices fetched live from the payment provider, and cancel.

Technology: Genuine Razorpay SDK integration; invoices always reflect the provider's current live view.

✓ LIVE & VERIFIED — Fully Operational

Razorpay Webhook Processing

Receives real payment events (payment succeeded, subscription cancelled, invoice paid) and automatically updates the organisation's subscription state — a failed card genuinely downgrades the account without anyone intervening.

Technology: Cryptographically verified (HMAC-SHA256) inbound webhook, fails closed if unverifiable; idempotent against redelivered events.

✓ LIVE & VERIFIED — Fully Operational

Custom Email Delivery (Organisation's Own AWS SES)

Lets an organisation send platform emails from its own domain through its own AWS SES account rather than the shared platform sender, so recipients see an address they recognise. Credentials are live-verified against AWS before being saved.

Technology: Real, live AWS boto3 credential verification at configuration time; secrets stored encrypted at rest.

✓ LIVE & VERIFIED — Fully Operational

Self-Service Rate Limit Visibility

Shows a customer their own current API rate limits, one labelled row per endpoint category, so an integrator can see exactly what they're allowed before hitting a limit in production.

Technology: Merges platform defaults with any organisation-specific overrides.

✓ LIVE & VERIFIED — Fully Operational

SIEM Export Configuration

Configures where an organisation's audit trail should be shipped for centralised security monitoring — the destination, format and credential — with the destination URL validated against internal-network targeting (SSRF) at the moment it's saved.

Technology: SSRF-protected destination validation; credentials stored one-way hashed.

✓ LIVE & VERIFIED — Fully Operational

Background Job Health Console

An operator view of every registered background job — which are registered, when each last ran, and whether it succeeded — reading the live, currently-running scheduler process rather than a static configuration file, so it reflects what's actually happening in production.

Technology: Live introspection of the running scheduler process, joined against a persistent run-log history.

✓ LIVE & VERIFIED — Fully Operational

Competitor Pricing Reference

CompliVibe's own competitive-research table of comparable platforms' pricing, deliberately marking any vendor without public pricing as such rather than inventing a number — every entry carries a real source URL.

Technology: Sourced, versioned reference data.

✓ LIVE & VERIFIED — Fully Operational

ROI Calculator (Lead Capture)

A prospect enters team size and current tooling spend and receives an estimated return on investment, computed from real, live subscription pricing rather than hard-coded numbers, with the underlying assumptions stated transparently alongside the result.

Technology: Live pricing-table-driven calculation with transparent assumption disclosure.

✓ LIVE & VERIFIED — Fully Operational

AM

DOMAIN 08 OF 19

Audit Management

[Internal & External Auditors](#) • [Compliance & GRC Teams](#)

Full audit-engagement lifecycle tracking, a secure external auditor portal, and a searchable, sourced marketplace of independent audit firms.

Audit Engagement Lifecycle

Tracks each audit as a record through its lifecycle — planned, fieldwork, reporting, closed — so the team always knows which audits are open and where each one stands, with a scope-impact view showing exactly which frameworks and controls a given engagement covers.

Technology: Guarded lifecycle state machine with live scope-to-compliance-data joins.

✓ LIVE & VERIFIED — Fully Operational

Audit Trail Read Access

A read-only, filterable window onto the organisation's complete audit log — who did what, to which record, and when — the evidence surface auditors and admins use to reconstruct history.

Technology: Filterable, org-scoped log query over a comprehensively written audit trail.

✓ LIVE & VERIFIED — Fully Operational

External Auditor Portal

Invites an external auditor to view a deliberately narrow, time-boxed slice of an organisation's compliance data — specific frameworks, controls, evidence and reports — without giving them a full user account. Every page the auditor views is separately logged.

Technology: Time-boxed, hashed bearer-token authentication distinct from ordinary logins; every scoped view is individually audit-logged.

✓ LIVE & VERIFIED — Fully Operational

Auditor Marketplace

A searchable directory of external audit firms filterable by framework, certification, verification status and day rate, with the ability to formally request an engagement, and honest advisory flags surfaced for each result (not verified, profile stale, rate near budget).

Technology: Rule-derived transparency flags, not opaque ranking.

✓ LIVE & VERIFIED — Fully Operational

VTR

DOMAIN 09 OF 19

Vendor & Third-Party Risk Management

Vendor Risk / Procurement • Security • Legal

The vendor register, real risk and criticality scoring, mitigation case tracking with an external vendor remediation portal, supply-chain graph mapping, and — among the most substantive engines in the platform — real sanctions, KYB and beneficial-ownership screening against live global registries.

Vendor Archive with Safeguards

Retires a vendor from the active register without deleting its history, genuinely refusing to archive a vendor that still has unfinished assessments or open mitigation cases.

Technology: Enforced pre-archive safety checks.

✓ LIVE & VERIFIED — Fully Operational

Vendor Due-Diligence Assessment Lifecycle

Runs a vendor due-diligence assessment through drafted, started, completed or cancelled, with automatic detection when an assessment has gone stale past its review date — genuinely raising a Risk and an alert, checked both on demand and by a fully automated daily sweep.

Technology: Automated daily staleness sweep with genuine risk-and-alert escalation.

✓ LIVE & VERIFIED — Fully Operational

Vendor Risk Scoring

Records a vendor risk score on the familiar likelihood-by-impact grid, banding it into a risk level and keeping every score ever recorded as a permanent, immutable history that automatically syncs the vendor's overall risk tier.

Technology: Immutable historical scoring with automatic tier synchronisation.

✓ LIVE & VERIFIED — Fully Operational

Vendor Criticality Tiering

Rates how business-critical a vendor is, separate from how risky it is, combining four organisation-weighted drivers into a 0–100 criticality score and band — deliberately kept as an independent axis from risk, not conflated with it.

Technology: Configurable, weighted scoring formula.

✓ LIVE & VERIFIED — Fully Operational

Vendor-to-Control Linking

Records which internal controls cover a given vendor, so a reviewer can see exactly what mitigates that supplier's risk, with links deactivated rather than deleted so history is preserved.

Technology: Link-history preservation.

✓ LIVE & VERIFIED — Fully Operational

Vendor Mitigation Cases

Opens a tracked case when a vendor problem needs fixing and moves it through defined stages until closed, with escalation and soft-deletion that never loses the audit trail — cases are also opened automatically the moment a questionnaire score crosses the risk threshold.

Technology: Automated case creation from questionnaire scoring; enforced status transitions.

✓ LIVE & VERIFIED — Fully Operational

Vendor Mitigation Actions

Breaks a mitigation case into individual remediation actions, each expected to be evidenced by the vendor, with internal staff able to submit evidence on the vendor's behalf and formally accept or reject it.

Technology: Structured action tracking with linked evidence.

✓ LIVE & VERIFIED — Fully Operational

Vendor Remediation Portal — Token Issuance

Issues a single, scoped access credential that lets an outside vendor log into a narrow remediation portal and respond to specific assigned actions, without ever creating a platform account for them.

Technology: One-time-display, action-scoped tokens, hashed at rest.

✓ LIVE & VERIFIED — Fully Operational

Vendor Remediation Portal — External Access

The vendor-facing side of the portal: an external supplier presents their token, sees only the actions assigned to them, and uploads evidence — which is automatically quarantined as "needs review" until internal staff formally approve it, so external submissions never silently count as accepted.

Technology: Token-scoped visibility with mandatory internal review before external evidence counts.

✓ LIVE & VERIFIED — Fully Operational

Vendor Supply-Chain Graph

Maps who your vendors depend on, so fourth- and fifth-party exposure hidden behind a direct supplier becomes visible, walking the dependency chain with genuine cycle protection and honest truncation flags if the network is too large to show in full.

Technology: Application-level graph traversal with real cycle detection and depth/size safety limits.

✓ LIVE & VERIFIED — Fully Operational

GDPR Subprocessor Register

Keeps the Article 28 register of subprocessors — location, and data-processing agreement status — genuinely refusing to accept a non-EEA subprocessor without a stated transfer mechanism, with a daily automated sweep chasing expiring agreements.

Technology: Enforced transfer-mechanism validation against a real EEA country set; automated daily reminder sweep.

✓ LIVE & VERIFIED — Fully Operational

Sanctions Screening

Checks a vendor's name against real international sanctions lists and flags matches or near-misses for human review, automatically escalating a confirmed hit to critical risk. Every vendor is re-screened automatically every single day, so a supplier sanctioned tomorrow is caught without anyone re-running anything.

Technology: Real integration with Moov Watchman plus a locally cached OFAC/OpenSanctions dataset; automated daily re-screening — one of the most substantive, genuinely live features on the platform.

✓ LIVE & VERIFIED — Fully Operational

Know-Your-Business (KYB) Verification

Runs a real know-your-business check on a vendor — legal entity existence, ultimate beneficial ownership, offshore-leaks records, and adverse media — automatically re-checked on a schedule, with each data source's availability status shown honestly rather than silently treated as clean when unavailable.

Technology: Real, live integrations with GLEIF, ICIJ Offshore Leaks, OpenOwnership and GDELT (all keyless); automated periodic re-screening.

✓ LIVE & VERIFIED — Fully Operational

Vendor Security Rating

Produces an external security rating for a vendor from its public internet footprint — web security headers, adverse media, IP abuse reports and breach history — refreshed automatically every 7 days, with an honest confidence percentage showing how much of the signal set was actually available.

Technology: Real integration with Mozilla Observatory and GDELT (plus optional keyed sources); automated weekly refresh with transparent confidence scoring.

✓ LIVE & VERIFIED — Fully Operational

DO

DOMAIN 10 OF 19

Data Observability

[Data Teams](#) • [Privacy/Legal](#) • [Security](#)

The data asset catalogue, real data-lineage graph mapping with external OpenLineage/OpenMetadata sync, obligation-coverage reporting, access-anomaly monitoring, geographic residency enforcement, retention sweeping, and incident case management.

Data Access Anomaly Monitoring

Keeps a record of who accessed which sensitive dataset and when, and raises a real alert when the pattern looks wrong (unusually high volume, an odd-hours access) against organisation-defined rules, with sensible default rules seeded automatically for every new organisation.

Technology: API-key-authenticated automated event ingestion; configurable anomaly rules.

✓ LIVE & VERIFIED — Fully Operational

Data Governance Dashboard

A single overview of the organisation's data-governance picture — asset counts, open data incidents, data-quality and retention-review status, and how much of the data estate is linked to a regulatory obligation — every figure computed live from real, current rows.

Technology: Live, multi-table SQL aggregation.

✓ LIVE & VERIFIED — Fully Operational

Data Lineage Graph & External Sync

Maps how data flows between systems — which table feeds which report — using a genuine bounded graph traversal, drawing what's upstream and downstream of any asset. Receives industry-standard OpenLineage events from external tools and performs a real, automated daily outbound sync to OpenMetadata.

Technology: Real bounded breadth-first graph search with cycle detection; genuine OpenLineage ingestion and automated daily OpenMetadata synchronisation.

✓ LIVE & VERIFIED — Fully Operational

Data-to-Obligation Coverage Reporting

Answers, in one number, what proportion of an organisation's data assets are actually tied to a regulatory obligation and where the blind spots are, broken down by link type and framework — computed live, with no estimation.

Technology: Live SQL aggregation.

✓ LIVE & VERIFIED — Fully Operational

Data Residency Policy Enforcement

Enforces rules about where data is allowed to physically live ("customer records must remain in India," "EU personal data must not leave the EEA"), checking every registered asset against those rules automatically every day and letting a team acknowledge, resolve, or formally waive each violation.

Technology: Genuinely continuous, fully automated daily enforcement sweep — violations surface without anyone pressing a button.

✓ LIVE & VERIFIED — Fully Operational

Data Retention Policy Enforcement

Ensures data is not kept longer than permitted — when an asset ages past its policy period, a review is opened, a task is assigned to the responsible owner, and a reminder is emailed, running fully automatically every day and correctly skipping any asset under active legal hold.

Technology: Fully automated daily sweep with genuine legal-hold protection.

✓ LIVE & VERIFIED — Fully Operational

Data Incident Case Management

Case management for data problems — a quality breach, unauthorised access, a residency violation — moved through a guarded lifecycle from new to resolved, with the ability to escalate an incident directly into a formal, linked compliance Issue when it warrants wider attention.

Technology: Guarded state-machine transitions with genuine, linked issue escalation; created both manually and automatically by the quality and access-monitoring engines.

✓ LIVE & VERIFIED — Fully Operational

IC

DOMAIN 11 OF 19

Integrations & Connectors

[Engineering / DevOps](#) • [Security](#) • [Compliance Ops](#)

Real, live connectors to AWS, Google Cloud, Azure, Okta, GitHub and major security scanners that turn native cloud and security tool output directly into compliance evidence, plus a browsable connector marketplace and a genuine platform-migration engine.

Cloud Evidence Connector Management

Sets up and maintains links between CompliVibe and cloud accounts — AWS, Google Cloud, Azure, Okta and GitHub — so security findings arrive automatically as compliance evidence, with signing secrets stored encrypted and a rule engine deciding which control each finding counts toward.

Technology: Encrypted secret storage; deterministic finding-to-control rule matching.

✓ LIVE & VERIFIED — Fully Operational

Cloud Connector Ingest Pipeline

The receiving end of the cloud connectors — each provider pushes security findings to a private, authenticated URL, and CompliVibe turns them into real evidence records attached to the right controls, making evidence collection continuous rather than a quarterly scramble. Each provider is authenticated using its own native, correct security model.

Technology: Provider-native authentication for each source (AWS HMAC, Google OIDC, Azure/Okta handshake, GitHub's own signature scheme) with deduplication and size-capped requests. Individually verified for AWS, GCP, Azure, Okta and GitHub.

✓ LIVE & VERIFIED — Fully Operational

Security Scanner Ingest

Accepts native output directly from Trivy, Prowler, OpenSCAP and Wazuh scanners and files the results as compliance evidence automatically, saving teams from manually attaching scan reports to controls.

Technology: Real, tool-specific parsers for each scanner's native output format, including full XML parsing for OpenSCAP.

✓ LIVE & VERIFIED — Fully Operational

Connector Marketplace

A browsable catalogue of third-party tools an organisation can switch on, with credentials stored encrypted and redacted on read, and a genuine, bounded, live connection test — honestly labelled when a connector has no network target to test.

Technology: Real outbound connectivity verification, transparently distinguished from configuration-only checks.

✓ LIVE & VERIFIED — Fully Operational

Platform Migration (Import Jobs)

Migrates an organisation's existing compliance data out of a competing platform (Vanta, Drata, Sprinto, Scrut) — upload an export, preview exactly what would be created, then commit — with a parity dashboard and gap report showing how much of the old platform's coverage carried over.

Technology: Real per-tool CSV/JSON/ZIP parsers including a genuine Drata export parser; dry-run preview before any data is written.

✓ LIVE & VERIFIED — Fully Operational

Automation Rule Authoring

Lets an organisation write its own "when this, then that" compliance rules — for example, automatically creating a task when a control's evidence goes stale — with every edit versioned and the prior definition snapshotted for a full change history.

Technology: Versioned rule authoring against nine supported condition types.

✓ LIVE & VERIFIED — Fully Operational

Automation Rule Execution

Actually runs those rules and performs the resulting work — creating real tasks, queuing real emails, updating real risks and controls — with a genuine dry-run mode that shows exactly what would happen without changing anything, and deterministic idempotency so re-running a rule never duplicates the work.

Technology: Concrete SQL-backed condition evaluation with idempotency-key-protected actions.

✓ LIVE & VERIFIED — Fully Operational



DOMAIN 12 OF 19

Issues & Tasks

[Compliance Ops](#) • [All Users](#)

The formal compliance issue register with a fully audited lifecycle, and organisation-directory-level configuration for how issue tracking behaves.

Issue Register

The central log of compliance problems — from an audit finding, a control failure, or a person reporting something — with type, severity, owner and status, and a dashboard rolling open issues up by severity and age.

Technology: Full audit-logged CRUD with soft delete.

✓ LIVE & VERIFIED — Fully Operational

Issue Workflow & Transition History

Assigns an issue to an owner and moves it through its lifecycle, keeping a permanent, tamper-evident history of every status change — who moved it, when, from what to what, and why — exactly what you'd show an auditor asking how an issue was handled.

Technology: Enforced-transition state machine with an immutable transition log.

✓ LIVE & VERIFIED — Fully Operational

Issue Configuration Settings

Per-organisation defaults for the issue module, such as default severity or owner applied to a newly created issue.

Technology: Get-or-create configuration record.

✓ LIVE & VERIFIED — Fully Operational

Issue Tracker Sync Configuration

The setup side of two-way synchronisation with Jira and Linear — registering a connection, storing credentials, defining how fields map across, and providing a full, searchable log of every sync event for troubleshooting.

Technology: Encrypted credential storage with full event-level sync logging.

✓ LIVE & VERIFIED — Fully Operational

AAC

DOMAIN 13 OF 19

Authentication & Access Control

[IT Admin](#) • [Security](#)

Session and permission infrastructure — membership management, enterprise SSO configuration, machine-to-machine provisioning credentials, the organisation directory, and IP-based network access restriction.

Current User Context

Tells the signed-in user exactly who they are and precisely what they're permitted to do inside a given organisation — the source of truth an interface uses to decide what to show.

Technology: Live permission resolution from role-to-permission mappings.

✓ LIVE & VERIFIED — Fully Operational

Invitation & Account Activation

Lets an administrator hand a colleague a one-time link that turns a pending invitation into a working account, with the invitee choosing their own password that the administrator never sees, and the raw activation token shown exactly once and never recoverable afterward.

Technology: One-way hashed, single-use activation tokens.

✓ LIVE & VERIFIED — Fully Operational

Membership & Role Management

Manages who belongs to an organisation and in what capacity — invite by email, change role, deactivate — with a hard rule that no change can ever leave an organisation without an owner, and an automatic check for whether a deactivated person was the sole accountable owner of any machine identity.

Technology: Enforced last-owner protection with automated orphan-identity detection.

✓ LIVE & VERIFIED — Fully Operational

SAML SSO Configuration

The administrative side of enterprise SAML single sign-on — register an identity provider, test the configuration, and turn it on or off — gated behind the organisation's billing plan.

Technology: Real, strict-mode `python3-saml` validation with RSA-SHA256 signature verification and replay protection.

✓ LIVE & VERIFIED — Fully Operational

OIDC SSO Configuration

The equivalent administrative surface for OpenID Connect single sign-on (Google Workspace, Microsoft Entra, Okta and similar), with a genuine live discovery call against the identity provider to confirm it's reachable before the configuration is saved.

Technology: Real `well-known` discovery verification; client secrets stored encrypted.

✓ LIVE & VERIFIED — Fully Operational

SCIM Provisioning Token Management

Issues and revokes the credentials an identity provider uses for automated user provisioning (SCIM), with the token shown once at creation and never again, and an optional expiry date.

Technology: One-time-display, one-way-hashed credential; gated behind the organisation's billing plan.

✓ LIVE & VERIFIED — Fully Operational

Organisation User Directory

A simple, authoritative list of the people in an organisation — the directory a compliance officer consults when deciding who to assign work to.

Technology: Shares the same underlying query as the platform's SCIM provisioning layer, so the two views can never disagree.

✓ LIVE & VERIFIED — Fully Operational

Role Catalogue

Lists every role available in an organisation together with the exact permissions each one actually grants — the reference an administrator checks before deciding what role to assign someone.

Technology: Live resolution against real role-permission records.

✓ LIVE & VERIFIED — Fully Operational

IP Address Allowlisting

Restricts access to an organisation to approved network ranges (office, corporate VPN), enforced centrally on every single request the moment a rule is saved, with built-in guards preventing an administrator from accidentally locking themselves out while configuring it.

Technology: Central, platform-wide enforcement on every organisation-scoped request; self-lockout protection.

✓ LIVE & VERIFIED — Fully Operational

RED

DOMAIN 14 OF 19

Reporting, Exports & Dashboards

[Executives & Board](#) • [Compliance & GRC Teams](#) • [Auditors](#)

On-demand report generation from live data, a real XBRL regulatory-filing export, custom report templates, board-level scorecards, and the organisation's core operational dashboards, activity timeline, and unified search.

On-Demand Report Generation

Produces a compliance report on demand — executive summary, framework readiness, evidence readiness, risk posture, task execution, control health or audit preparation — assembled from what is genuinely recorded in the platform at that exact moment, with a dry-run mode to preview before saving.

Technology: Live, multi-table SQL aggregation; every figure and sentence is computed, not templated placeholder text.

✓ LIVE & VERIFIED — Fully Operational

Report Library & Provenance

The library view over previously generated reports — list, open with full sections, see a roll-up summary, inspect exactly what data a report was built from, and archive without ever deleting the underlying record.

Technology: Full provenance tracking down to the underlying source data.

✓ LIVE & VERIFIED — Fully Operational

Live Framework Readiness Score

Answers "how ready are we for this framework right now" — control coverage, how much of that coverage is backed by evidence, and exactly where the gaps are — a live calculation reflecting the platform's current state at the moment it's requested.

Technology: Live, multi-table SQL computation, not a cached or stale figure.

✓ LIVE & VERIFIED — Fully Operational

Board Scorecard Report

Builds the board-level compliance scorecard — overall posture, framework readiness, top risks, and key risk indicator movement — with a written summary suitable for a board pack, assembled from deterministic template text rather than a generative model.

Technology: Live SQL computation with fixed, deterministic narrative templates — no AI narrative generation.

✓ LIVE & VERIFIED — Fully Operational

XBRL Regulatory Export

Exports a report as a genuine XBRL 2.1 instance document — the structured disclosure format regulators and exchanges accept — validated by loading it through a real industry-standard validation library.

Technology: Hand-built, standards-compliant XBRL generation, independently validated via the Arelle library.

✓ LIVE & VERIFIED — Fully Operational

Custom Report Templates

Lets an organisation define its own report layouts — which sections appear, in what order — instead of being limited to built-in report types, with a set of ready-to-use ESG disclosure templates provided out of the box.

Technology: Full CRUD with race-safe automatic seeding of system templates.

✓ LIVE & VERIFIED — Fully Operational

Custom Report Generation

Runs a custom template against live platform data, executing real section builders that each query their own source tables, so a bespoke report layout produces the same quality of genuine content as the built-in reports.

Technology: Eleven real section builders drawing from eighteen underlying data tables.

✓ LIVE & VERIFIED — Fully Operational

Export Attestation Signing

Lets an authorised person formally sign a statement about an export bound cryptographically to that specific export, so the statement cannot later be moved to a different file — creation is gated behind a passed integrity check first.

Technology: Combined hash-and-signature binding tying the statement directly to the export's checksum.

✓ LIVE & VERIFIED — Fully Operational

Organisation Export Branding

Controls how exported documents look for the whole organisation — logo, colours, footer text — with a built-in staleness flag when branding hasn't been reviewed in 180 days.

Technology: Get-or-create configuration with automatic staleness detection.

✓ LIVE & VERIFIED — Fully Operational

Compliance Dashboard

The organisation's main dashboard — overall compliance posture, framework readiness, control health, a risk heatmap, and a recent-activity feed built directly from genuine, recorded audit-log events rather than a synthetic feed.

Technology: Live, multi-table SQL aggregation across 20+ tables.

✓ LIVE & VERIFIED — Fully Operational

Dashboard Summary

A compact, nine-field rollup of an organisation's compliance position — obligations, frameworks, risks, tasks, score, controls, vendors and policies — for the top of the home screen, guaranteed to always agree with the full dashboard because it reuses the exact same underlying calculations.

Technology: Shared calculation engine with the full compliance dashboard, preventing the two views from ever disagreeing.

✓ LIVE & VERIFIED — Fully Operational

Global Command Palette

A keyboard-driven quick-search bar reaching any risk, control, vendor, issue, policy or obligation, with fuzzy matching so a partial or misspelled term still finds the right record, and a small set of direct actions (like creating a task) executable right from the search box.

Technology: Real search-engine-backed (Meilisearch) fuzzy matching; degrades gracefully with a clear indicator if the search engine is temporarily unreachable.

✓ LIVE & VERIFIED — Fully Operational

Compliance Activity Timeline

A single chronological stream of everything happening across the compliance programme — evidence collected, control tests run, risks raised, issues opened, deadlines reached — merged from six separate sources into one view.

Technology: Merged, multi-source live query with per-source truncation indicators.

✓ LIVE & VERIFIED — Fully Operational

Compliance Inbox

A personal "what needs me today" list pulling together everything genuinely waiting on a specific user — assigned tasks, auditor evidence requests, policy attestations, policy approvals and control-exception approvals — in one place.

Technology: Real per-user aggregation across five distinct work-item sources.

✓ LIVE & VERIFIED — Fully Operational

Global Search

One search box across the whole platform — risks, controls, vendors, issues, policies and obligations — with genuine fuzzy matching so a partial or misspelled term still returns results, narrowable to specific record types.

Technology: Real search-engine integration (Meilisearch), not a simple database text scan; kept continuously in sync from audit events.

✓ LIVE & VERIFIED — Fully Operational

RM

DOMAIN 15 OF 19

Risk Management

[Risk Management](#) • [Executives & Board](#) • [Finance](#)

The organisation's core risk register with genuine inherent/residual scoring and control-linked coverage, plus a real, published-methodology quantitative loss-modelling engine.

Risk Register

The organisation's risk register — every identified risk with likelihood, impact, owner, treatment decision and current score, showing both the inherent risk (before controls) and the residual risk (after the specific controls actually linked and implemented), with a 5×5 heatmap and a relationship graph view.

Technology: Real, live residual-risk recalculation driven directly by which controls are actually linked and marked implemented — not a static override.

✓ LIVE & VERIFIED — Fully Operational

Risk Quantification (FAIR / Monte Carlo)

Puts a genuine currency figure on a risk instead of a 1–25 score — an expected annual loss, a 90% confidence range, and a full loss-exceedance curve showing the probability of exceeding any given loss amount. Implements the industry-standard FAIR methodology with real statistical sampling, exactly the kind of analysis a CFO or insurer would ask for.

Technology: Genuine Beta-PERT statistical sampling via numpy across three real methodologies including a Bayesian model (PyMC); 10,000-iteration default simulation with sensitivity ranking and materiality flagging.

✓ LIVE & VERIFIED — Fully Operational

ACP

DOMAIN 16 OF 19

AI-Assisted Communication & Platform Infrastructure

[Compliance Ops](#) • [IT Admin](#)

Real, working transactional email infrastructure (templates, delivery queue, worker), Slack/Teams compliance-bot subscriptions, the organisation-wide AI-drafting on/off control, and comprehensive evidence management with genuine cloud storage and AI-assisted review.

Email Template Management

Lets an organisation define the reusable email bodies the platform sends — reminders, notifications, digests — with named placeholders, and a preview showing exactly how a template will render before anyone receives it. A strict allowlist prevents a template from ever pulling in unintended data.

Technology: Enforced variable allowlist on every render.

✓ LIVE & VERIFIED — Fully Operational

Email Outbox Administration

The administrative view of outbound email — queue a message, see everything queued or sent, open one with its full delivery history, cancel before it goes out, or mark it sent or failed by hand, with every state change permanently logged.

Technology: Full delivery-event audit trail on every message.

✓ LIVE & VERIFIED — Fully Operational

Email Delivery Worker

The genuine delivery machinery behind the outbox — safely hands out queued messages to a sender with proper database locking so two workers never grab the same message, retries failures up to three times, and permanently sets aside anything that keeps failing. Driven automatically by a real, scheduled process sending via AWS SES.

Technology: Real `SELECT ... FOR UPDATE SKIP LOCKED` database locking; genuine AWS SES delivery on a fully automated schedule — one of the platform's most reliably automated queues.

✓ LIVE & VERIFIED — Fully Operational

Compliance Bot Subscriptions (Slack/Teams)

Lets a user opt in to receiving compliance updates in Slack or Microsoft Teams — a chosen daily digest time and whether to receive SLA breach alerts — with a genuine staleness flag if a digest hasn't arrived on schedule.

Technology: Deduplicated, per-user, per-platform subscription management.

✓ LIVE & VERIFIED — Fully Operational

Compliance Bot Message Outbox

Shows the recent bot messages generated for the calling user on a given platform — a transparent, readable log of exactly what the bot produced.

Technology: Direct, filterable message-log read access.

✓ LIVE & VERIFIED — Fully Operational

AI Drafting Organisation Toggle

A single organisation-level switch that turns AI-assisted drafting on or off across the platform. While it's off, every AI drafting surface genuinely refuses to run — a real, enforced gate rather than a cosmetic preference, for organisations whose policy prohibits sending content to a third-party model.

Technology: Enforced gate checked before every single AI drafting call in the platform.

✓ LIVE & VERIFIED — Fully Operational

Evidence Register

The evidence vault — every document, screenshot, report or attestation proving a control is working, including who reviewed it, when it was collected, and when it goes stale, with readiness reporting showing exactly which controls have no evidence at all.

Technology: Full audit-logged CRUD with soft archival; live SQL-driven coverage-gap reporting.

✓ LIVE & VERIFIED — Fully Operational

Evidence-to-Control Linking

Connects evidence to the control or controls it supports, so coverage reporting knows what's genuinely proven and an auditor can trace any claim straight back to its backing document.

Technology: Tenant-validated linking with a proper 404 on any cross-organisation attempt.

✓ LIVE & VERIFIED — Fully Operational

Evidence File Upload (Cloudflare R2)

Attaches the actual file to an evidence record rather than only a link — a real cloud object-storage upload with a server-computed cryptographic checksum verifying the real bytes received, and time-limited, secure download links for sharing with an auditor.

Technology: Genuine Cloudflare R2 (S3-compatible) storage; server-side SHA-256 checksum computed from the real uploaded bytes, replacing any client-supplied claim.

✓ LIVE & VERIFIED — Fully Operational

Evidence AI Assessment

After a file is uploaded, an AI model reads it and offers a genuine second opinion — what the document appears to be, whether it plausibly covers the linked control, and what looks missing — running fully automatically in the background. Strictly advisory: it never marks, blocks, or fails a piece of evidence itself, and any failure is honestly reported rather than hidden.

Technology: Automated, scheduled processing via a Groq/Azure AI model chain, real document-text extraction from the uploaded file; assess-not-certify by design — a human always makes the final call.

✓ LIVE & VERIFIED — Fully Operational

Evidence Automation Rules

Defines standing rules for evidence that should arrive automatically from a webhook, monitored mailbox, or form — what triggers collection and how the incoming data maps onto an evidence record — with health indicators showing when a rule has stopped producing evidence.

Technology: Validated trigger and transform configuration with built-in staleness detection.

✓ LIVE & VERIFIED — Fully Operational

Evidence Automation Ingest

Three real inbound channels — webhook, parsed email, form submission — that turn an incoming payload directly into a genuine evidence item against the matching rule, with built-in deduplication so a retried delivery never creates duplicate evidence.

Technology: Idempotency-key-protected automated ingestion across three independent channels.

✓ LIVE & VERIFIED — Fully Operational

Evidence Package Assembly

Assembles a bundle of evidence for a specific audit or framework — the "here's everything you asked for" deliverable — with a manifest listing exactly what's inside and a completeness view showing what's still missing against the framework's actual obligations.

Technology: Live completeness computation against real obligation and scope data.

✓ LIVE & VERIFIED — Fully Operational

Audit Evidence Package Export

Produces a single, formatted, downloadable document (PDF or Word) containing an audit engagement's evidence, optionally narrowed to one framework — the printable companion to the structured evidence package, always rendered fresh from current data.

Technology: Live document rendering, re-assembled from current data on every export.

✓ LIVE & VERIFIED — Fully Operational



DOMAIN 17 OF 19

Vendor Security Questionnaires

Vendor Risk • Sales / Customer Security

Both directions of the security-questionnaire process — managing questionnaires sent by customers to you, and sending your own questionnaires to vendors — with real scoring and a genuine, evidence-based auto-draft engine.

Inbound Questionnaire Sessions

Handles the security questionnaires customers and prospects send to your organisation — each incoming questionnaire becomes a session grouping all its questions, with progress tracking and a guard preventing completion until every answer has been reviewed.

Technology: Enforced completion gating — a session cannot close with unreviewed items.

✓ LIVE & VERIFIED — Fully Operational

Inbound Questionnaire Question Items

The individual questions inside an inbound questionnaire, each carrying the customer's text, a proposed answer, and a formal review state so a human always signs off before anything is sent back.

Technology: Enforced review-then-send state machine.

✓ LIVE & VERIFIED — Fully Operational

Outbound Vendor Questionnaire Responses

Sends a questionnaire to a vendor and tracks their response — creating the response automatically pre-creates a blank answer row for every question in the template, so progress is visible from the very first moment.

Technology: Automatic answer-shell generation with enforced status transitions.

✓ LIVE & VERIFIED — Fully Operational

Questionnaire Template Library

The reusable questionnaire library — templates organised into sections and questions, with three ready-made templates covering roughly fifty questions shipped out of the box, deliberately non-editable so every organisation's baseline stays directly comparable.

Technology: Protected system templates ensuring cross-organisation comparability.

✓ LIVE & VERIFIED — Fully Operational

Questionnaire Template Authoring

Lets an organisation build its own questionnaires, most usefully by cloning a system template and adapting it — a genuine deep copy that correctly re-attaches every copied question to its correctly copied section.

Technology: Verified deep-copy cloning with full ID remapping.

✓ LIVE & VERIFIED — Fully Operational

TCC

DOMAIN 18 OF 19

Trust Center & Customer Commitments

[Sales / Customer-Facing Security](#) • [Legal](#) • [Marketing](#)

A public-facing trust page showing an organisation's genuine security posture to prospects and customers, plus tracking of contractual commitments made to customers with automated triggering and notification.

Public Trust Center Page

A public page prospects and customers can visit without logging in, showing display name, contact details, current (non-expired) certifications, per-framework control coverage computed live, and published policy summaries — expired certifications are automatically filtered out so a lapsed credential is never shown as current.

Technology: Live control-coverage calculation reused directly from internal readiness dashboards; automated expiry filtering.

✓ LIVE & VERIFIED — Fully Operational

Public Trust Center Document Access Requests

Lets a prospect on the public trust page request access to non-public documents by submitting their email and a reason, with the compliance team automatically notified and duplicate submissions from the same email prevented.

Technology: Automatic deduplication and email notification to compliance managers.

✓ LIVE & VERIFIED — Fully Operational

Trust Center Administrative Configuration

The administrative side of the trust page — turning it on, setting the display name, tagline, logo, contact email, custom message, choosing which sections appear, and claiming the public URL, with the slug protected against accidental change once an established public URL is live.

Technology: Regex-validated, organisation-unique slug with confirm-to-change protection.

✓ LIVE & VERIFIED — Fully Operational

Customer Commitments Register

Tracks promises made to customers in contracts — breach notification windows, uptime undertakings, audit rights — each with a named internal owner accountable for it, validated as a genuinely active member of the organisation.

Technology: Membership-validated ownership assignment.

✓ LIVE & VERIFIED — Fully Operational

Customer Commitment Lifecycle & Auto-Trigger

Moves a commitment from active to triggered when an obligating event occurs, then to fulfilled or waived, with the owner notified at every step. Triggers both by hand and fully automatically — a detected incident can trip a breach-notification commitment on its own, backed by a genuine daily automated sweep.

Technology: Enforced-transition state machine with real, automated event-driven and scheduled triggering, and genuine email notifications at every step.

✓ LIVE & VERIFIED — Fully Operational

Customer Commitment Dashboard

A single summary view of the organisation's customer commitments — active, triggered, fulfilled, breached — including a genuine, computed service-level compliance rate rather than a stored placeholder figure.

Technology: Live SLA-compliance-rate calculation.

✓ LIVE & VERIFIED — Fully Operational



DOMAIN 19 OF 19

Governance Override Templates

[Compliance & GRC Teams](#) • [IT Admin](#)

Reusable, versioned blueprints that pre-configure the approval requirements for rare, high-stakes governance override requests.

Governance Override Templates

Reusable, versioned blueprints for break-glass override requests, capturing the override type, target record type, and condition rules that automatically decide how many approvals are needed and which roles may grant them, based on genuine, live facts about the actual record being overridden.

Technology: Live-fact-driven condition evaluation with full version-history snapshotting on every edit.

✓ LIVE & VERIFIED — Fully Operational

About This Catalog

CompliVibe operates 249 confirmed, fully working capabilities across 19 areas of AI governance and compliance — spanning AI risk management, regulatory frameworks, policy lifecycle, vendor risk, data observability, evidence management, audit operations, privacy, and platform administration.

Every feature in this document does exactly what its description says: each one is reachable in the live product, performs genuine work against real data (not placeholder or mocked output), and is backed by a passing automated test. Where a feature uses a real external integration — a cryptographic signature, a live regulatory data feed, a cloud provider API, or an AI model — that is stated plainly in the technology line, and nowhere in this document does an AI model make an unreviewed decision on an organisation's behalf; every AI-assisted capability in CompliVibe is advisory, with a human always making the final call.

This document intentionally excludes any capability that is only partially working, carries a known defect, or exists in the codebase but is not yet automatically triggered — even where those capabilities are visible elsewhere in the product today. A separate, internal engineering register tracks that work in progress.

Prepared July 19, 2026 • CompliVibe Confidential